Phishing Analysis 2

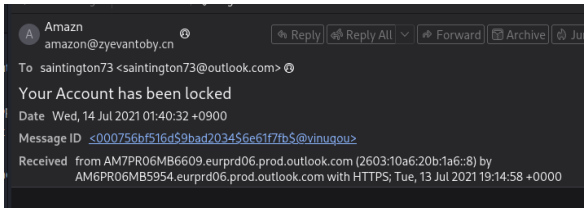
1. Kịch bản

- Phân loại và thu thập thông tin về chiến dịch phishing

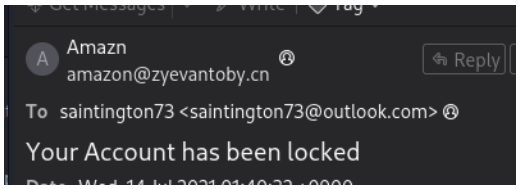
2. Write-up

1. What is the sending email address?

- Domain có vấn đề, đây không phải domain của amazon
- cn là tên miền quốc gia của Trung Quốc → email lừa đảo

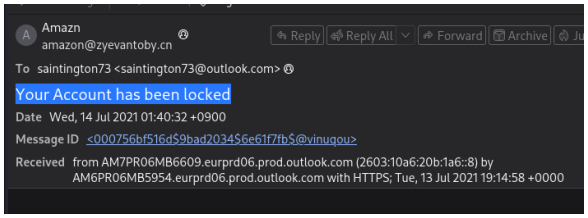


2. What is the recipient email address?



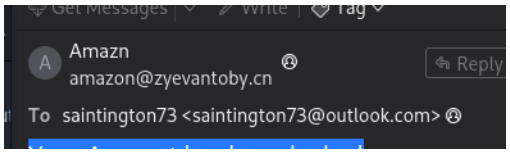
3. What is the subject line of the email?

- Subject cho biết nội dung chính của email

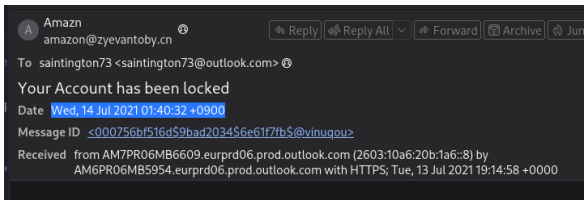


4. What company is the attacker trying to imitate?

- Như đã phân tích địa chỉ email đang cố gắng giả mạo là email từ amazon

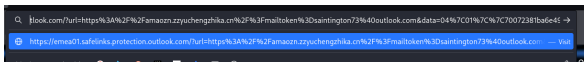


5. What is the date and time the email was sent? (As copied from a text editor)



6. What is the URL of the main call-to-action button?

- Truy vấn URL nhiều tham số và dài bất thường



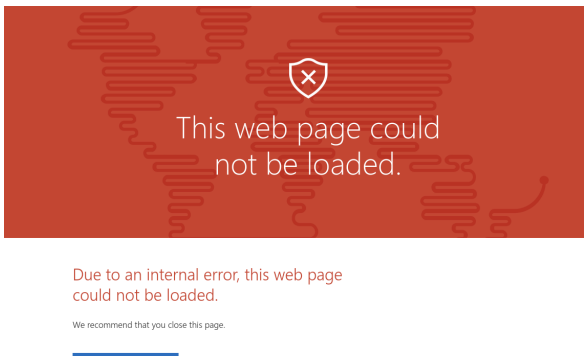
```
https://emea01.safelinks.protection.outlook.com/?
url=https%3A%2F%2Famaozn.zzyuchengzhika.cn%2F%3Fmailtoken%3Dsaintington73%40outlook.com&
data=04%7C01%7C%7C70072381ba6e49d1d12d08d94632811e%7C84df9e7fe9f640afb435aaaaaaaaaaaa%7C1%7C
0%7C637618004988892053%7CUnknown%7CTWFpbGZsb3d8eyJWIjoiMC4wLjAwMDAiLCJQIjoiV2luMzIiLCJBTiI6Ik
1haWwiLCJXVCI6Mn0%3D%7C1000&sdata=oPvTW08ASiViZTLfMECsvwDvguT6ODYKPQZNK3203m0%3D&reserved=0
```

- safelinks.protection.outlook.com: quét và bọc link để bảo vệ user
  - Nó không giúp link an toàn mà chỉ quét và giám sát link trước khi redirect
- Nếu không bị chặn → dẫn tới URL gốc đã mã hóa
- Giải mã URL: → đây là domain phishing giả mạo domain của amazon với mailtoken là email của người nhận

https://amaozn.zzyuchengzhika.cn/?mailtoken=saintington73@outlook.com&
data=04|01||70072381ba6e49d1d12d08d94632811e|84df9e7fe9f640afb435aaaaaaaaaaaa|1|0|637618004988892053|Unkn

7. Look at the URL using URL2PNG. What is the first sentence (heading) displayed on this site? (regardless of whether you think the site is malicious or not)

- Sử dụng URL đã giải mã: https://amaozn.zzyuchengzhika.cn/?mailtoken=saintington73@outlook.com



8. When looking at the main body content in a text editor, what encoding scheme is being used?

- KIểm tra mục Content-Transfer-Encoding

```
        charset="utf-8"
Content-Transfer-Encoding: base64

ICAgICAgICAgICAgICAgICAgICAgICAgIA0KICAgIA0KSGVsbG8gRGVhciBDdXN0b21lciwNCg0K
WW91ciBhz7LPsm91bnQgYWNjZXNzIGhhcyBiZWVuIGxpbWl0ZWQuIFdlJ3ZlIG5vdGljZWQgc2ln
bmlmaWNhbnQgY2hhbmdlcyBpbiB5b3VyIGHPss+yb3VudCBhY3Rpdml0eS4gQXMgeW91ciBwYXlt
ZW50IHByb2Nlc3MsIFdlIG5lZWQgdG8gdW5kZXJzdGFuZCB0aGVzZSBjaGFuZ2VzIGJldHRlcg0K
DQpUaGlzIExpbWl0YXRpb24gd2lsbCBhZmZlY3QgeW91ciBhYmlsaXR5IHRvOg0KzqFheS5DaGFu
Z2UgeW91ciBwYXltZW50IG1ildGhvZC5CdXkgb3IgcmVkZWVtIGdpZnQgY2FyZHMuQ2xvc2UgeW91
ciBhz7LPsm91bnQuDQpXaGF0IHRvIGRvIG5leHQ6DQoNClBsZWFzZSBjbGljayB0aGUgbGluayBh
Ym92ZSBhbmQgZm9sbG93IHRoZSBzdGVwcyBpbiBvcmRlciB0byBSZXZpZXcgVGhlIEFjY291bnQs
IElmIHdlIGRvbid0IHJlY2VpdmUgdGhlIGluZm9ybWF0aW9uIHdpdGhpbiA3MiBob3VycywgWW91
ciBhz7LPsm91bnQgYc+yz7Jlc3MgbWF5IGJlIGxvc3QuDQoNCg0KICAgICAgICAgICAgICAgICAg
ICAgICAgICAgICAgICAgIA0KDQoNCg0KDQoNCg0KDQoNClJldmlldyBBY2NvdW50
DQoNCg0KWW91cnMgU2luY2VyZWx5LCANCg0KQW1hem9uIFN1cHBvcnQgVGVhbQ0KQ29weXJpZ2h0
IMKpIDE5OTktMjAyMSBBbWF6b24uIEFsbCByaWdodHMgcmVzZXJ2ZWQuDQoNCg0KICAgICAgICAg
ICAgICAgICAgICAgICAgICAgICAgICAgICAgICAgICAgICAgICANCg0KDQoNCg0KDQogDQo=

 ------=_NextPart_000_0232_018D8931.1E363E20
Content-Type: text/html;
        charset="utf-8"
Content-Transfer-Encoding: base64

PCFET0NUWVBFIEhUTUw+PGh0bWw+PGhlYWQ+CjxtZXRhIGh0dHAtZXF1aXY9IkNvbnRlbnQtVHlw
```


9. What is the URL used to retrieve the company's logo in the email?

- Giải mã dữ liệu thu được trong text editor → thu được đoạn mã HTML của email

```
cellpadding="0">
  <TBODY>
  <TR>
    <TD width="600" align="center" valign="top"
      style="width: 600px;"> <IMG width="749" height="67" style="width: 100px;"
      alt="" src="https://images.squarespace-cdn.com/content/52e2b6d3e4b06446e8bf13ed/1500584238342-OX2L298XVSKF8AO6I3SV/amazon-logo?format=750
w&amp;content-type=image%2Fpng"
      border="0" hspace="0">
      <TABLE width="100%" class="templateContainer" border="0" cellspacing="0"
      cellpadding="0">
        <TBODY>
```


10. For some unknown reason one of the URLs contains a Facebook profile URL. What is the username (not necessarily the display name) of this account, based on the URL?

```
Sincerely, </EM></SPAN></SPAN><BR></P>
<DIV style="text-align: center;"><A href="https://emea01.safelinks.protection.outlook.com/?url=https%3A%2F%2Fwww.facebook.com%2Famir.boyk
a.7&amp;data=04%7C01%7C%7C7007238fba6e49d1d12808d94632811e%7C84df9e7fe9f640afb435aaaaaaaaaaa%7C1%7C0%7C637618004988892053%7C
Unknown%7CTWFpbGZsb3d8eyJWIjoiMC4wLjAwMDAiLCJQIjoiV2luMzIiLCJBTiI6Ik1haWwiLCJXVCI6Mn0%3D%7C1000&amp;sdata=KV%2BG1%2BFO3v3AL
NVowA1PrenHiT3aT%2Flvb5y1KxkAkc%3D&amp;reserved=0" originalSrc="https://www.facebook.com/amir.boyka.7" shash="GensOMRql5Vqvbx8WtI2HuCQojKi
Owg7AD9+j3Isp1MJ8kbk6EbXKYUYje6INStWQ4xNG6Tfa9JLrYG51E0Azr3pMKAdzbJV1i+mX09meMM6wMYdF1GPgi0vTMLrYM5G4WnQk+Kl7F1gVlC5jEXJj6
gDuMhhhYhET3oiHhypl="
```


- Giải mã URL thu được: https://www.facebook.com/amir.boyka.7" shash="GensOMRql5Vqvbx8WtI2HuCQojKiOwg7AD9+j3Isp1MJ8kbk6EbXKYUYje6INStWQ4xNG6Tfa9JLrYG51E0Azr3pM
- Tên người dùng thu được nằm ở cuối đường dẫn của link facebook

3. Kết luận

- Email từ người gửi có dấu hiệu phishing giả mạo email của amazon với tld có nguồn gốc trung quốc
- Email giải mạo email thông báo khóa tài khoản với button điều hướng đến URL lạ chứa emailtoken là email người dùng. Viện sử dụng token này là để xác định người dùng đã nhấn link, gửi mã độc,...
- Xuất hiện URL chứa trang tài khoản facebook, lừa người dùng login để đánh cắp thông tin tài khoản